
NONPROFIT AI RESOURCES · MANDY HATHAWAY CONSULTING

AI Vendor Accountability for Nonprofits

What to ask before you sign anything

Mandy Hathaway Consulting · mandyhathaway.com · AI Ethics & Technology Consulting

Signing up for a new software tool used to be a relatively low-stakes decision for most nonprofits. The main questions were cost and fit. AI tools raise a different set of questions, because what happens to your data after you start using a tool matters in ways that traditional software often did not.

This guide covers what to ask AI vendors before committing, what the answers should tell you, and what red flags to take seriously. It is written for nonprofit leaders and operations staff who are not lawyers, and who need practical guidance rather than contract review expertise.

Vendor accountability starts before the contract, not after. The questions you ask during evaluation tell

you more about a vendor than anything in their marketing materials.

The questions that matter most

1 Do you use customer data to train your AI models?

This is the threshold question. The answer should be specific, not vague. "We take privacy seriously" is not an answer. "We do not use data from paid plans to train models, and we offer a data processing addendum that specifies this" is an answer. If the vendor cannot give a clear yes or no, assume the answer is yes.

2 How long do you retain input data, and where is it stored?

Some tools retain conversation and input data indefinitely unless you delete it. Others process and discard immediately. Retention periods matter for privacy compliance and for your overall data footprint. Server location matters if your funders have data sovereignty requirements.

3 Do you offer a Data Processing Agreement (DPA)?

A DPA is a contract that specifies exactly how the vendor handles your organization's data, including retention, security standards, breach notification, and sub-processor disclosures. Reputable enterprise vendors have standard DPAs available. If a vendor cannot provide one, that is a significant signal about their suitability for use with any sensitive information.

4 What are your security certifications?

SOC 2 Type II is the most common certification for cloud software vendors. HIPAA Business Associate Agreement capability matters if you handle health information. Asking for certifications tells you both what the vendor has achieved and how seriously they take the question.

5 What happens to our data if we cancel?

You should know, before you start, how to get your data out and what happens to it after you leave. A vendor that cannot answer this question clearly is a vendor who has not thought carefully about data lifecycle.

6 What is your breach notification process?

If the vendor experiences a security incident that affects your data, how quickly will they notify you, and through what channel? "We will notify you in accordance with applicable law" is minimally acceptable. A specific timeframe and designated contact is better.

Understanding the difference between consumer and enterprise terms

Many AI tools offer both a free or consumer tier and a paid enterprise or business tier. The terms of service can be meaningfully different between these plans, particularly around data training and retention.

READ THE TERMS FOR YOUR SPECIFIC PLAN

A vendor's consumer product may use inputs for training while the same vendor's enterprise product does not. The company's general privacy policy may not distinguish between plans clearly. Always read the terms for the specific plan your organization is on, not the company's general privacy page. If the terms are ambiguous, ask for written clarification before using the tool with sensitive data.

Red flags to take seriously

- 🚩 The vendor cannot or will not answer data training questions directly.
- 🚩 Terms of service require you to grant broad rights to use your content or inputs.
- 🚩 No DPA is available, or the vendor has not heard of the term.

- ▀ Security certifications are absent or the vendor is evasive when asked.
- ▀ The vendor is a recent startup with no track record and no transparency about their data practices.
- ▀ The pricing has changed significantly since you signed up, suggesting business model instability.
- ▀ Breach notification language is absent from the terms or is vague about timing.
- ▀ There is no clear process for exporting or deleting your data.

None of these is automatically disqualifying in isolation, but a pattern of them — or any single flag on a tool that will handle sensitive client data — warrants serious caution.

When a vendor relationship changes

Vendor terms are not static. Pricing changes, data policies are updated, products are acquired or shut down. For any tool your organization relies on meaningfully, build in a periodic check: at least once a year, review the current terms and confirm they still align with your organization's requirements.

ANNUAL VENDOR REVIEW CHECKLIST

Has the vendor changed their data processing or training policy in the past year?

Is the DPA we signed still current, or has the vendor issued an updated version?

Have there been any reported security incidents involving this vendor?

Has pricing changed in a way that affects our budget planning?

Are we still using this tool in the way we intended when we adopted it, or has use drifted?

Does this vendor still meet our current compliance requirements?

Exiting a vendor relationship

At some point, every vendor relationship ends — either because you switch tools, the vendor shuts down, or the terms change in ways you cannot accept. The time to plan for this is before you are in it, not during.

For any tool where your organization's data accumulates, know your export process before you need it. Download conversation histories, exported reports, or any other organizational data that lives in the vendor's platform on a regular schedule. Treat vendor-stored data the same way you would treat data stored on a device that could fail — back it up on your own terms before you are forced to.

Mandy Hathaway

AI Ethics & Technology Consulting for Nonprofits

mandyhathaway.com · [Book a call](#)